

Data Classification Policy

Table of contents

1. Purpose	2
2. Scope	3
3. Policy statements	3
4. Classification levels	3
4.1 Public	3
4.2 Internal	4
4.3 Confidential	4
4.4 Restricted	4
5. Classification criteria	5
5.1 Impact scale	5
6. Responsibilities	5
6.1 Data Owners	5
6.2 Data Custodians — Cloud Infrastructure	6
6.3 CISO's office (Data Protection function)	6
6.4 All personnel	6
7. Control requirements by classification	6
8. Classification procedures	7
8.1 Initial classification	7
8.2 Periodic review	7
8.3 Changing a classification	8
9. Handling requirements	8
9.1 Labelling	8
9.2 Storage and transmission	8
9.3 Access	8
10. Compliance and enforcement	8
11. Integration with related policies	9
12. Training and awareness	9
13. Review and updates	9

Title	Data Classification Policy
Doc#	POL-DATA-001
Version	1.2 (DRAFT)
Date	12-04-2024
Supersedes	POL-DATA-001 v1.1 (15-01-2024)
Next Review	12-10-2024
Owner	CISO — I. Ferreira
Approved By	[Pending — Head of Compliance, M. Dubois]
ISO/IEC 27001:2022	A.5.12 Classification of information; A.5.13 Labelling of information; A.5.14 Information transfer

*Status: **DRAFT v1.2** — pending Head of Compliance sign-off.* Until this version is endorsed, handling follows the legacy Data Handling Guidelines (POL-DH-002) where they do not conflict with the principles set out below. *(M. Dubois: the POL-DH-002 reference is stale — that document was rolled into this policy in the 2024 Q3 tidy-up. Strike it before sign-off, and check the date in the control table: my working draft carries 14-03-2025, not the April 2024 date shown above.)*

Related policies: Access Control (POL-SECU-021), Data Management (POL-DATA-015), Data Protection (POL-DATA-004), Incident Response (POL-SECU-010), Privacy (POL-DATA-022). *(Cross-reference list refreshed 2025-03; one entry may still point at a retired number — verify against the document register before circulating.)*

1. Purpose

This policy sets out how Tessera classifies the information it creates, receives, and processes — across the SaaS platform, the internal corporate estate, and the managed-cloud environments we run for tenants — so that each asset receives protection proportionate to the harm its disclosure, alteration, or loss would cause. Classification is the first link in the chain: it tells Data Owners what to protect, tells Engineering how to build, and tells the Security team where to look.

Classification decisions made under this policy must satisfy Tessera’s obligations under the *Privacy Act 1988* (Cth) — in particular **APP 11**, which requires Tessera to take such steps as are reasonable to protect the personal information it holds — together with the information classification, labelling, and transfer controls of **ISO/IEC 27001:2022** (Annex A **A.5.12**, **A.5.13**, **A.5.14**). Where a dataset attracts a stronger regime by contract — **PCI DSS** for payment-card data we process on a tenant’s behalf, or a tenant’s own healthcare obligations for US providers we host — the higher requirement applies. Tessera is not itself a US covered entity and no classification decision should assume HIPAA as the default frame.

2. Scope

This policy applies to all information assets held by Tessera or on its tenants' behalf, in whatever form and on whatever medium — production tenant data, source code, corporate records, email, and physical documents — and to everyone who handles them: employees, contractors, and vendors operating under a data processing arrangement.

The policy does not attempt to enumerate every system. Where a new service is introduced, its default classification is **Internal** pending a formal decision by the Data Owner.

3. Policy statements

Tessera requires that:

- (a) every information asset carries a classification of **Public**, **Internal**, **Confidential**, or **Restricted**, assigned at creation or acquisition;
- (b) classification is applied before an asset is shared, placed in a shared system, or transmitted off-platform;
- (c) the controls in §7 are applied according to the assigned level, and where data of different classifications is mixed the highest level governs;
- (d) classification is reviewed at least annually, and whenever the business or regulatory context changes; and
- (e) classification decisions and their rationale are recorded so they can be audited.

4. Classification levels

Tessera uses a four-tier scheme. The tiers are ordered; each inherits the obligations of the tier below it.

4.1 Public

Information cleared for release outside Tessera.

- *Examples:* published marketing material, the tessera.com.au website, issued press releases, public product documentation.
- *Protections:* standard availability and integrity controls; no confidentiality restriction, though release still follows the communications process.

4.2 Internal

Information for use within Tessera that is not sensitive enough to warrant stronger controls, but is not intended for publication.

- *Examples:* internal procedures and runbooks, the staff directory, internal project trackers, draft documentation, most source code held in Tessera repositories.
- *Protections:* valid Tessera credentials required; encrypted in transit; no storage on unmanaged personal accounts.

[Reviewer, 2025-04-03: §4.2 says “valid Tessera credentials” but contractors and several vendors legitimately reach Internal systems via federated SSO. Tighten the wording to “authenticated Tessera or federated identity” before this goes out.]

4.3 Confidential

Sensitive information whose unauthorised disclosure would cause significant harm to Tessera, its people, or its tenants — commercially, legally, or reputationally.

- *Examples:* tenant contracts and commercial terms, board and executive papers, unpublished financial results, employee personal information held by HR, pre-announcement strategic plans.
- *Protections:* role-based access with manager approval; encryption at rest and in transit; secure disposal on retirement.

4.4 Restricted

The most sensitive category: information whose disclosure could cause severe harm, enable fraud or identity theft, or place Tessera in breach of its regulatory obligations.

- *Examples:* tenant records and tenant personal information held on the platform, production secrets (access keys, certificates, passwords), security incident records and audit trails, payment-card data covered by PCI DSS, the Statement of Applicability (DOC-SEC-003) and the supporting risk registers.
- *Protections:* multi-factor authentication; encryption at rest with managed keys; strict need-to-know access; detailed audit logging; segregated storage.

[I. Ferreira, margin note: the line between Confidential and Restricted still turns on “significant harm” versus “severe harm.” We keep promising the team a worked example — a borderline tenant dataset — and never deliver one. Add it to Appendix A before the Stage 1 audit, or reviewers will read the two definitions as interchangeable.]

5. Classification criteria

A Data Owner assigning a classification weighs, in order:

1. **Legal and regulatory exposure.** Does the data attract a statutory protection? Personal information triggers APP 11 and the Notifiable Data Breaches scheme; payment data triggers PCI DSS; tenant records attract contractual data-processing terms.
2. **Contractual obligations.** What has Tessera promised the tenant, or a vendor promised Tessera, about handling and retention?
3. **Business impact of disclosure.** The confidentiality, integrity, and availability consequences, scored against the four levels above.
4. **Aggregation effect.** Individually low-sensitivity records can become Restricted in aggregate — a single tenant record is Restricted; a tenant roster is no less so.
5. **Retention and cross-border considerations.** Where the data must be held, for how long, and whether it may leave Australian soil. (*Data that must remain in-country is flagged at classification time so the Sydney-primary region preference in POL-DATA-004 can be enforced.*)

[Reviewer, 2025-03-19: criterion 5 says “Sydney-primary,” but POL-DATA-004 names ap-southeast-2 as primary with a cross-region standby rather than in-country-only. Confirm whether we are committing to data-sovereignty confinement before this wording is quoted in a tenant DPA.]

5.1 Impact scale

For impact scoring only — it does not replace the four tiers — consequences are rated:

- **Low** — negligible operational, reputational, or compliance effect.
- **Moderate** — manageable with management attention.
- **High** — material effect requiring executive involvement.
- **Severe** — threatens continuity, a regulatory position, or tenant trust.

The four-tier classification remains the authoritative control trigger; the impact scale informs the Data Owner’s judgement and the severity rating of any incident touching the data.

6. Responsibilities

6.1 Data Owners

Data Owners are the senior staff accountable for a given information domain — for example, the CTO (Dr S. Qureshi) for platform architecture artefacts, the CFO (P. Nair) for financial records, the Head of People (A. Desai) for HR data. A Data Owner:

- assigns and signs off the initial classification for assets in their domain;
- authorises access within their domain on a need-to-know basis;
- reviews classifications at least annually and on material change;
- is accountable for the control gaps their classification implies.

Ownership of shared or cross-domain datasets is agreed between the relevant Data Owners and recorded in the data inventory maintained under POL-DATA-015.

6.2 Data Custodians — Cloud Infrastructure

Day-to-day custody of classified data sits with **Cloud Infrastructure**, led by C. Hayes (Cloud Infrastructure Architect) under the **Head of IT**, H. Boyd. Data Custodians:

- implement the technical controls a classification requires — encryption, key management, access enforcement, segregation;
- monitor compliance with classification-specific controls and report exceptions;
- manage encryption keys and access control systems in line with POL-DATA-004;
- escalate suspected misclassification or mishandling to the CISO's office.

6.3 CISO's office (Data Protection function)

The classification scheme itself is owned by the **CISO, I. Ferreira**, whose office:

- maintains this policy and the supporting handling guidance;
- runs periodic classification audits and spot checks;
- investigates classification violations and recommends corrective action; and
- coordinates with Legal and Compliance on regulatory exposure.

6.4 All personnel

Everyone who handles Tessera information applies the correct classification to what they create, handles information at its marked level, completes classification training during onboarding and at each annual refresher, and reports suspected misclassification or mishandling to the Security team without delay.

7. Control requirements by classification

Control area	Public	Internal	Confidential	Restricted
Storage	Any approved system	Tessera-approved systems	Approved systems, encrypted at rest	Segregated, encrypted at rest with managed keys
Access	No restriction	Authenticated Tessera / federated identity	Role-based, manager-approved	MFA, need-to-know; CISO's office approves elevated access
Transmission	Any	Encrypted in transit	End-to-end encryption	Encrypted channel + recipient verification
End-point storage	Allowed	Allowed	Allowed with disk encryption	Prohibited on unmanaged devices
Disposal	Standard deletion	Secure deletion, verified	Certified secure destruction	Witnessed secure destruction with certificate
Logging	Standard	Standard	Access logged	Detailed access + administrative logging
Retention	Per business need	Per business need / contractual	Per legal & contractual requirement	Explicit approval to retain beyond minimum

[Reviewer, 2025-03-12: the “Endpoint storage — Prohibited on unmanaged devices” row for Restricted will collide with the managed-BYOD position in the access policy. Reconcile the carve-out before sign-off.]

8. Classification procedures

8.1 Initial classification

1. The creator or acquirer runs the sensitivity check in §5.
2. Apply the decision tree (see Appendix A) to settle the tier.
3. If the call is borderline, consult the Data Owner; for tenant-adjacent data, default up to Restricted.
4. Record the classification and rationale in the data inventory.
5. Apply the label and the controls in §7.

8.2 Periodic review

Data Owners review their holdings at least annually, re-score against §5, update the classification where the context has moved, and notify Cloud Infrastructure of any resulting control change. Reviews are diarised in the ISMS calendar.

8.3 Changing a classification

Only the Data Owner may change a classification. An upgrade takes effect immediately with its controls; a downgrade is held for 30 days so that access granted on the earlier basis can be re-confirmed. All changes are logged with their business justification and the CISO's office is notified.

9. Handling requirements

9.1 Labelling

- Physical documents carry the classification in the header and footer.
- Electronic files carry it in filename or document metadata; where a system cannot store metadata, the label lives in the enclosing folder or repository convention. (*C. Hayes: a number of the legacy S3 buckets still carry no classification tag — tracked under tidy-up ticket TS-1412.*)
- Email bearing Confidential or Restricted content carries the classification in the subject line; presentations carry it on each slide.

9.2 Storage and transmission

Confidential and Restricted data is stored only in approved systems, encrypted at rest, and transmitted over encrypted channels. Restricted data is not stored on unmanaged personal devices or personal cloud accounts. Backup media inherits the classification of its source.

9.3 Access

Access is granted on a need-to-know basis by the Data Owner. Confidential access requires the relevant manager's approval; elevated or standing access to Restricted data requires the CISO's office. Guest, contractor, and vendor access is time-bound and provisioned through the joiner-mover-leaver process (**ISMS-PR-014**), with revocation handled on the same procedure — access is removed within 24 hours of a termination or role change.

10. Compliance and enforcement

Compliance is monitored through access logging, periodic Data Owner reviews, and audit by the CISO's office. A data loss prevention capability is being rolled out to enforce transmission controls; until it is live, those controls rely on engineered safeguards and manager oversight. (*I. Ferreira: do not promise DLP enforcement in any tenant-facing text until the rollout under TS-1380 ships — reword if this section is quoted externally.*)

Violations are handled under the HR disciplinary framework: minor or inadvertent breaches through coaching and retraining; deliberate or repeated violations through formal disciplinary action, access review, and, where warranted, referral to law enforcement. Emergency access that overrides these controls is granted only through the break-glass procedure in the Incident Response policy (POL-SECU-010).

11. Integration with related policies

- **Access Control (POL-SECU-021)** — classification drives role-based access and MFA requirements; session timeouts are set per the access policy (admin consoles 15 minutes, standard sessions 30).
- **Data Management (POL-DATA-015)** — the handling matrix and retention periods live there; this policy defines the tiers they key off.
- **Data Protection (POL-DATA-004)** — encryption standards, key management, and the Sydney-primary region.
- **Incident Response (POL-SECU-010)** — classification sets incident severity and breach-notification posture under the NDB scheme.
- **Privacy (POL-DATA-022)** — the APP 11 obligations this policy operationalises.

12. Training and awareness

Classification training is part of onboarding — completed before production access is granted — and refreshed annually. Data Owners and Custodians receive additional role-specific briefings. Completion is tracked in the HRIS by the Head of People's team; the Security team maintains the content and the case studies, drawn from appropriately anonymised real handling decisions.

13. Review and updates

This policy is reviewed annually, and additionally when the regulatory or contractual landscape shifts, when the platform or client base changes materially, or after any significant incident involving classified data. The *Next Review* date in the control table is the governing trigger; if it has passed, the policy is treated as overdue and escalated. Updates require approval by the CISO (technical changes) and the Head of Compliance (regulatory changes); framework-level changes go to the Executive Risk Committee.